

Progetto 02/05

Scenario:

Un dipendente dell'ufficio amministrativo riceve un'email che sembra provenire dalla sua banca aziendale (Intesa Sanpaolo), comunicando il blocco di un bonifico in uscita da 27.800€ per presunta frode.

Obiettivo dello spear phishing: Indurre la vittima a cliccare sul link per "sbloccare" il bonifico e inserire le credenziali bancarie aziendali su un sito clone.

Contenuto della mail:

Oggetto: Blocco urgente – Bonifico aziendale da 27.800€ sospeso per attività anomala

Da: sicurezza@intesasanpaolo.com

A: contabilità.generale@azienda.it

Data: Giovedì, 2 Maggio 2025 – 09:14

Gentile Cliente,

Il sistema di monitoraggio delle transazioni ha rilevato un'anomalia nel bonifico in uscita n. 874509-B di **€ 27.800,00** eseguito in data odierna verso il beneficiario:

Société Nouvelle Import S.A. – IBAN: FR76 1030 6020 3050 0007 6543 201

Per motivi di sicurezza, l'operazione è stata **temporaneamente bloccata** in attesa di conferma da parte del titolare.

Per evitare ritardi nei pagamenti e sanzioni contrattuali, **ti invitiamo a verificare e convalidare immediatamente l'operazione** cliccando sul seguente link sicuro:

[Accedi al Portale Imprese](#)

Se non riceveremo conferma entro **1 ora**, l'operazione verrà **annullata automaticamente** e sarà inoltrato un alert all'Unità Antifrode Banca d'Italia.

Cordiali saluti,

Ufficio Sicurezza Online

Intesa Sanpaolo – Divisione Business

supporto-clienti@intesa.it

Spiegazione scenario:

Perché è credibile:

- Fa leva su una situazione **urgente e ad alto rischio finanziario**.
- Riporta un importo elevato, il nome del beneficiario, un IBAN credibile, e riferimenti realistici.
- Il linguaggio è formale e professionale.
- Usa il logo e il nome della banca.
- Spinge il destinatario a reagire velocemente per evitare conseguenze indesiderate.

Campanelli d'allarme:

- **Dominio falso:** intesianpaoIo.com con la "I" di "Paolo" scritta come una "I" maiuscola.
- **Pressione temporale e minaccia legale:** tipica strategia per far saltare la lucidità alla vittima.
- **Email generica:** nessun riferimento personalizzato (nome, partita IVA, codice cliente).